

Threat Modeling di una Agentic Filler Pipeline per Digital Human in tempo reale

Progetto per il corso di
Sicurezza delle Architetture Data Intensive (6 CFU)

Prof. Ernesto Damiani

Università degli Studi di Milano
Corso di Laurea Magistrale in Sicurezza Informatica

Studenti: Marta Finazzi
Alessio Bonora

Luglio 2026

Indice

1	Abstract	1
2	Introduzione e obiettivi	1
2.1	Contesto	1
2.2	Perché il sistema è agentic	1
2.3	Obiettivi dell'analisi	2
3	Scope e metodologia	2
3.1	Oggetto dell'analisi	2
3.2	Processo di threat modeling	2
4	Descrizione della pipeline agentic	3
4.1	Architettura dual-brain	3
4.2	Ruoli, azioni e privilegi attesi	4
4.3	Fast-Brain Agent	4
4.4	Deep-Brain Agent	4
4.5	Orchestrazione e stati	5
4.6	Assunzioni architetturali	5
5	Attacker model	5
5.1	Profili di attaccante	5
5.2	Obiettivi di sicurezza	6
6	Data Flow Diagram e trust boundary	6
6.1	DFD di livello 0	6
6.2	DFD di livello 1	7
7	Asset model	7
7.1	Proprietà di sicurezza	7
7.2	Data assets	8
7.3	Model assets	9
7.4	Supporting agentic assets	9
8	Identificazione delle minacce	9
8.1	STRIDE-AI applicato direttamente alle threat concrete	9
8.2	Applicabilità dell'OWASP Top 10 for Agentic Applications	11
9	Risk prioritization	11
9.1	Criteri	11
9.2	Matrice qualitativa	12
9.3	Priorità dei rischi principali	12

10 Scenari di minaccia prioritari	12
10.1 Scenario 1 — Goal hijack del Fast-Brain	12
10.2 Scenario 2 — Feedback poisoning persistente	13
10.3 Scenario 3 — Identity and privilege abuse tra agenti	13
10.4 Scenario 4 — Tampering e replay dei messaggi inter-agent	14
10.5 Scenario 5 — Voice clone abuse e human-agent trust exploitation	14
11 Controlli secondo le sette precauzioni	15
11.1 Precauzione 1 — Least Agency	15
11.2 Precauzione 2 — Guardrail deterministici e HITL	15
11.3 Precauzione 3 — Sandboxing e controllo granulare degli accessi	16
11.4 Precauzione 4 — Audit trail completo e immutabile	16
11.5 Precauzione 5 — Supply chain control	16
11.6 Precauzione 6 — Continuous execution monitoring	16
11.7 Precauzione 7 — Audit periodici ispirati ad AIVSS	17
12 Secure architecture proposal	17
12.1 Fail-safe behavior	18
13 Trade-off sicurezza–latenza	18
14 Piano di validazione sperimentale	19
14.1 Esperimento A — Fast-Brain security harness	19
14.2 Esperimento B — Feedback poisoning simulation	19
14.3 Esperimento C — Sicurezza dei messaggi inter-agent	20
15 Rischio residuo	21
16 Limitazioni	21
17 Conclusioni	22
A JSON Schema semplificato del Fast-Brain	22
B Formato sicuro del messaggio inter-agent	23
C Matrice di tracciabilità	23

1 Abstract

Questo progetto presenta il threat modeling di una pipeline agentica progettata per ridurre la latenza percepita durante l'interazione con un digital human. L'architettura adotta un modello *dual-brain*: un **Fast-Brain Agent** produce rapidamente un filler verbale e un trigger gestuale, mentre un **Deep-Brain Agent** elabora la risposta principale tramite LLM, RAG e memoria contestuale. I due percorsi sono eseguiti in parallelo e coordinati da un orchestratore che gestisce priorità, transizione audio-video, fallback e sincronizzazione.

L'analisi è deliberatamente centrata sulla natura **agantica** del sistema. Come indicato per questa traccia, non viene applicata una FMEA: le minacce sono identificate direttamente a partire da asset, agenti, azioni, tool, memorie, identità e trust boundary. Il processo combina **STRIDE-AI**, le proprietà di sicurezza CIA³-R e l'**OWASP Top 10 for Agentic Applications 2026**. La relazione definisce lo scope, esplicita le assunzioni architetturali, costruisce un attacker model, valuta l'applicabilità dei rischi OWASP e approfondisce cinque scenari prioritari: goal hijack del Fast-Brain, poisoning persistente del feedback, abuso di identità e privilegi tra agenti, tampering/replay dei messaggi inter-agent e sfruttamento della fiducia tramite voice cloning.

Le mitigazioni sono organizzate secondo le sette precauzioni discusse nel corso: Least Agency, guardrail deterministici e Human-in-the-Loop, sandboxing e controllo granulare degli accessi, audit trail immutabile, controllo della supply chain, monitoraggio continuo e audit periodici ispirati ad AIVSS. Il risultato è una proposta di architettura sicura che preserva il requisito di bassa latenza mediante controlli sincroni deterministici, fallback fail-safe e controlli più costosi spostati fuori dal percorso critico.

2 Introduzione e obiettivi

2.1 Contesto

La traccia considera una pipeline per digital human nella quale il percorso STT–LLM–TTS–Lip-Sync-streaming presenta una latenza incompatibile con una conversazione percepita come naturale. Il requisito di progetto assume un tempo percepito di prima risposta inferiore a circa 800 ms e riporta, nello stato iniziale della pipeline, latenze che possono arrivare a decine di secondi. Per mascherare l'attesa viene introdotto un ciclo agentico di filler contestuali, più credibili di una semplice animazione statica o di una frase ripetitiva [1].

L'istanza applicativa usa un avatar con personalità coerente, voce clonata e comportamento gestuale. La personalità allegata al progetto descrive una figura anziana emiratina, con stile materno, uso del dialetto locale e riferimenti a rimedi tradizionali. Tali caratteristiche aumentano il realismo, ma anche il potere persuasivo dell'output e quindi la rilevanza di autenticità, safety e tutela della fiducia dell'utente [4, 5].

2.2 Perché il sistema è agentic

Secondo il materiale del corso, un sistema agentico combina inferenza e azione, può invocare servizi esterni, comunicare tramite memoria condivisa o persistente e coordinarsi con altri agenti senza supervisione umana passo per passo [2]. La pipeline analizzata soddisfa tali caratteristiche perché:

- il Fast-Brain interpreta un input parziale e decide filler, tono e trigger gestuale;
- il Deep-Brain recupera contesto dal RAG e genera la risposta sostanziale;
- l'orchestratore prende decisioni su fork, ordine di riproduzione, timeout, fallback e stitching;
- il sistema invoca servizi di STT, TTS, generazione video, voice cloning e lip-sync;

- feedback e memoria possono influenzare le interazioni future;
- l'output del Fast-Brain viene emesso prima che il percorso principale sia completato.

2.3 Obiettivi dell'analisi

Gli obiettivi sono:

1. definire con precisione architettura, scope e assunzioni;
2. identificare gli asset Data, Model e gli asset agentici di supporto;
3. individuare minacce concrete senza passare da una FMEA;
4. classificare le minacce tramite STRIDE-AI e OWASP Agentic;
5. prioritizzare i rischi in base a likelihood, impact e amplificatori agentici;
6. proporre controlli coerenti con le sette precauzioni del corso;
7. progettare una secure architecture compatibile con il vincolo real-time;
8. definire un piano sperimentale riproducibile senza inventare risultati non misurati.

Scelta metodologica. La FMEA non viene applicata. Il threat model parte direttamente da asset, agenti, trust boundary, identità, memorie, tool e azioni. La FMEA rimane appropriata per analizzare guasti e failure mode di pipeline AI tradizionali, ma non è richiesta per questa traccia agentica.

3 Scope e metodologia

3.1 Oggetto dell'analisi

L'oggetto è la **pipeline agentica dual-brain** che maschera la latenza della generazione audiovisiva. Il Deep-Brain usa internamente il percorso RAG e i servizi multimediali; tali componenti sono inclusi soltanto nella misura in cui rappresentano memorie, tool o superfici d'attacco raggiungibili dagli agenti.

Sono inclusi:

- input vocale o testuale, VAD e streaming STT;
- Fast-Brain e Deep-Brain;
- orchestratore e messaggi inter-agent;
- RAG, memoria di sessione, eventuale memoria persistente e feedback;
- TTS filler, TTS principale, voice cloning, generazione video e lip-sync;
- identità di servizio, credenziali, policy, log e artefatti intermedi;
- output audio-video verso l'utente.

Sono fuori scope, salvo che vengano introdotti in implementazioni future:

- code interpreter, shell e valutazione dinamica di codice generato;
- accesso dell'agente a sistemi amministrativi esterni;
- modifica autonoma di risorse cloud o database operativi;
- strumenti non descritti nella traccia.

3.2 Processo di threat modeling

Il processo adottato è:

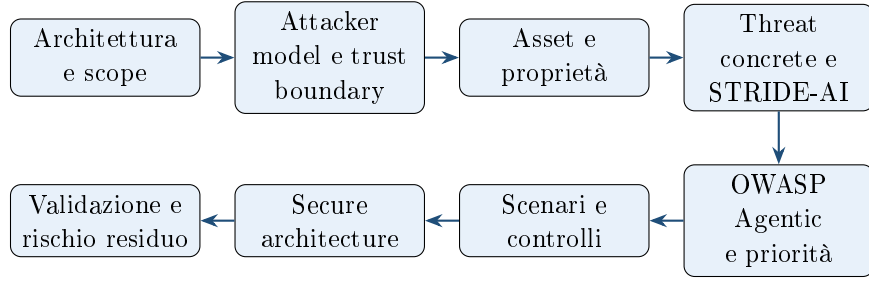


Figura 1: Processo adottato per la pipeline agentic.

La metodologia STRIDE-AI mantiene un approccio asset-centered e adatta le categorie classiche di STRIDE agli asset AI/ML [6, 7]. Per i rischi specifici degli agenti viene usata la tassonomia OWASP Agentic 2026. Le sette precauzioni del corso sono usate come struttura della strategia di mitigazione [2].

4 Descrizione della pipeline agentic

4.1 Architettura dual-brain

La pipeline esegue in parallelo due percorsi:

- **Fast path:** riceve un partial transcript, identifica una categoria d'intento e produce un filler breve più un trigger comportamentale;
- **Deep path:** riceve la trascrizione completa, interroga il RAG e genera la risposta principale.

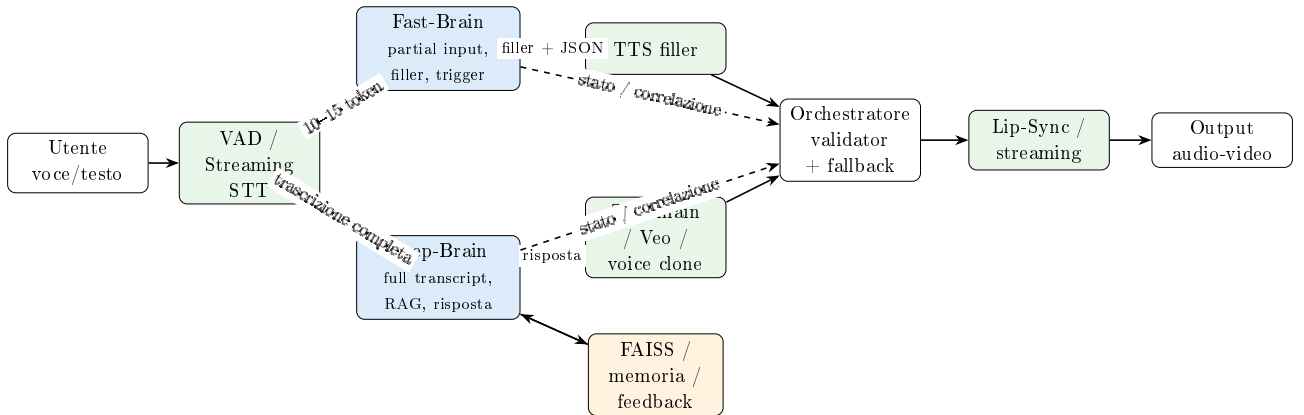


Figura 2: Pipeline agentic dual-brain analizzata.

4.2 Ruoli, azioni e privilegi attesi

Tabella 1: Ruoli agentici e principio di least agency atteso.

Componente	Input	Output/azione	Accessi strettamente necessari
Fast-Brain	Partial transcript, categoria d'intento, estratto minimo della personalità	Filler breve, intent label, trigger da insieme finito	Output validator e TTS filler; nessun accesso diretto a FAISS, memoria persistente o voice asset
Deep-Brain	Trascrizione completa, contesto RAG, memoria di sessione	Risposta principale	Retrieval read-only, memoria di sessione, TTS main
Orchestratore	Stato dei due percorsi, output validati, segnali temporali	Fork, scheduling, timeout, fallback, stitching	Invocazione dei servizi multimediali secondo policy; nessun contenuto decisionale autonomo
Feedback Manager	Feedback esplicito e segnali impliciti	Proposta di modifica di ranking o few-shot pool	Feedback store; aggiornamenti persistenti mediati da policy e, per quelli ad alto impatto, HITL
RAG Retriever	Query del Deep-Brain	Chunk con provenienza e score	FAISS read-only durante l'inferenza
Voice Service	Testo validato e riferimento autorizzato	Audio sintetizzato	Voice embedding protetto; nessun accesso al RAG

4.3 Fast-Brain Agent

Il Fast-Brain è progettato per generare un riconoscimento contestuale entro un budget ridotto. Il prompt di sistema limita il compito a un filler di massimo 12 parole e richiede un output JSON strutturato. Il Fast-Brain non deve rispondere alla domanda, richiedere dati all'utente, dare consigli sostanziali o selezionare liberamente strumenti.

Un possibile output logico è:

Listing 1: Output logico del Fast-Brain.

```
{
  "session_id": "9f4b...",
  "intent": "complex_analytical",
  "trigger": "GAZE_UP_LEFT",
  "filler": "That is an important question; let me consider it carefully.",
  "sequence": 12
}
```

Il JSON non è un confine di sicurezza di per sé. Deve essere validato da un componente deterministico indipendente prima di raggiungere TTS e animazione.

4.4 Deep-Brain Agent

Il Deep-Brain riceve la trascrizione completa e genera la risposta principale. Il percorso può includere:

- query expansion e retrieval su indice FAISS;
- contesto RAG con metadati e provenienza;
- memoria di sessione e, se prevista, memoria persistente;

- few-shot examples e system/personality prompt;
- TTS, voice cloning e generazione video.

La memoria persistente non è assunta come scrivibile direttamente dall'utente. Qualora il feedback possa aggiornare ranking o few-shot pool, tali aggiornamenti costituiscono un'azione privileged separata dall'inferenza.

4.5 Orchestrazione e stati

L'orchestratore deve implementare una macchina a stati esplicita:

1. ricezione input e apertura della sessione;
2. fork dei due percorsi;
3. validazione del Fast-Brain;
4. emissione del filler oppure fallback statico;
5. preparazione della risposta principale;
6. transizione controllata filler-main;
7. chiusura della sessione e registrazione dell'audit trail.

La race condition “Double-Speak” non è un'elevation of privilege. È un rischio di integrità dello stato e disponibilità/qualità del servizio, da trattare tramite state machine, lock logico, idempotenza e timeout.

4.6 Assunzioni architetturali

Tabella 2: Assunzioni utilizzate nel threat model.

ID	Assunzione	Effetto sull'analisi
A1	Fast-Brain, Deep-Brain e orchestratore sono processi o servizi distinguibili	È possibile applicare identità e privilegi separati
A2	Il Fast-Brain non necessita di accesso diretto a RAG o memoria persistente	Qualunque accesso rappresenta eccessive agency o privilege abuse
A3	Il feedback può influenzare ranking o few-shot pool, ma non dovrebbe aggiornare direttamente la knowledge base	Il feedback è un vettore di poisoning da mediare
A4	TTS, voice cloning o generazione video possono essere servizi esterni	Si introducono trust boundary, supply-chain risk e data disclosure
A5	I messaggi inter-componenti possono attraversare una rete interna o un message bus	Sono richiesti autenticità, integrità, freschezza e binding alla sessione
A6	Il requisito di latenza impedisce controlli generativi pesanti nel fast path	I controlli sincroni devono essere deterministici e il fallback deve essere fail-safe
A7	Non sono presenti shell, code interpreter o eval() di output dell'agente	ASI05 è non applicabile nello scope corrente, salvo estensioni future

5 Attacker model

5.1 Profili di attaccante

Tabella 3: Attacker model.

ID	Attaccante	Accesso iniziale	Capacità	Obiettivi principali
AT1	Utente esterno malevolo	Canale voce/testo e feedback	Prompt injection, input ripetuti, manipolazione linguistica, replay lato client	Goal hijack, disclosure, degradazione del servizio
AT2	Utente autenticato/Sybil	Più account o sessioni valide	Feedback coordinato, query adattive, osservazione dei cambiamenti nel ranking	Poisoning persistente e manipolazione del few-shot pool
AT3	Attaccante di rete interno	Accesso a rete interna, bus o proxy compromesso	Intercettazione, modifica, replay e spoofing dei messaggi	Confondere agenti e orchestratore, corrompere lo stato
AT4	Insider o amministratore malevolo	Accesso a storage, prompt, log o pipeline di deploy	Modifica di modelli, prompt, index, policy o voice asset	Persistenza, impersonazione, copertura delle tracce
AT5	Fornitore o dipendenza compromessa	Modello, libreria, TTS, voice service o generatore video	Aggiornamento malevolo, telemetria indebita, comportamento backdoored	Supply-chain compromise ed esfiltrazione
AT6	Agente compromesso	Controllo logico del Fast-Brain o Deep-Brain	Uso delle identità e dei tool assegnati, produzione di output formalmente validi ma malevoli	Propagazione downstream e abuso dei privilegi

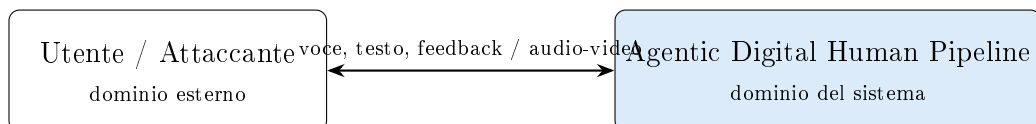
5.2 Obiettivi di sicurezza

Gli obiettivi prioritari sono:

- impedire che l'input utente ridefinisca il goal degli agenti;
- confinare il blast radius di ogni agente compromesso;
- proteggere memoria, RAG, prompt, voice asset e feedback da modifiche non autorizzate;
- garantire autenticità e freschezza dei messaggi inter-agente;
- assicurare che l'output audiovisivo sia attribuibile alla versione corretta di modello, voce e policy;
- mantenere la disponibilità senza bypassare i controlli di sicurezza in caso di timeout.

6 Data Flow Diagram e trust boundary

6.1 DFD di livello 0

**Figura 3:** DFD livello 0.

6.2 DFD di livello 1

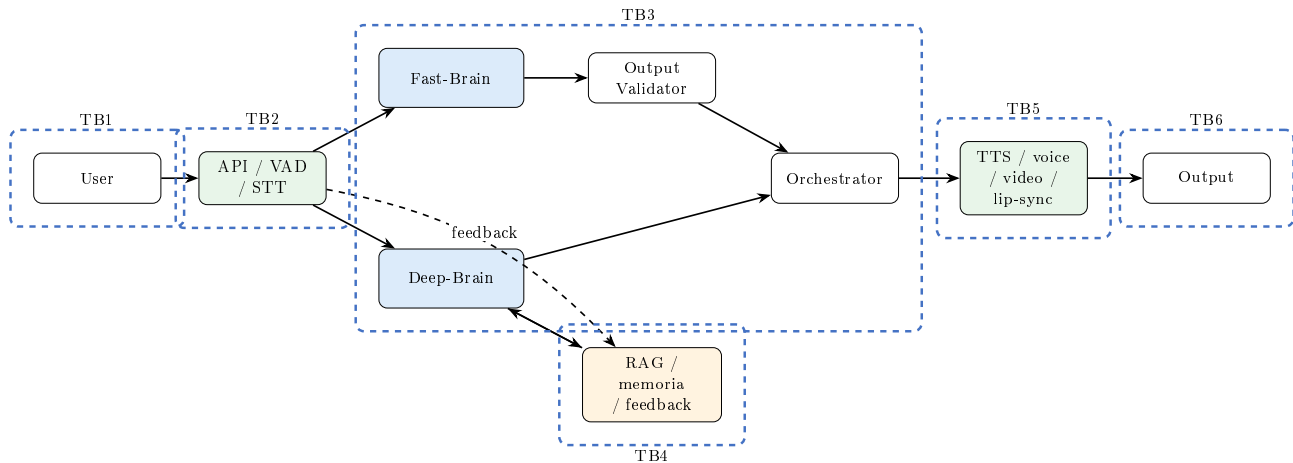


Figura 4: DFD livello 1 e principali trust boundary.

Tabella 4: Trust boundary e requisiti di sicurezza.

TB	Confine	Dati/azioni	Rischi dominanti
TB1	Utente esterno ↔ edge	Voce, testo, feedback, session ID	Spoofing, prompt injection, flooding, feedback manipulation
TB2	Edge → agenti	Partial transcript, full transcript, intent preliminare	Truncation, goal hijack, PII leakage, session mix-up
TB3	Agenti ↔ orchestratore	Filler, trigger, risposta, completion signal	Identity spoofing, tampering, replay, state desynchronization
TB4	Deep-Brain ↔ RAG/memoria	Query, chunk, embedding, score, feedback update	Poisoning, cross-user leakage, unauthorized write
TB5	Orchestratore ↔ media services	Testo, voice reference, prompt visuale, audio e video intermedi	Tool misuse, supply chain, provider disclosure, artifact tampering
TB6	Output → utente	Video, audio, metadata, provenance	Impersonazione, output tampering, assenza di disclosure AI

7 Asset model

7.1 Proprietà di sicurezza

La metodologia considera le proprietà CIA³-R richiamate nel materiale del corso: Confidentiality, Integrity, Availability, Authenticity, Authorization e Non-repudiation [3]. Nel caso del digital human assumono particolare rilievo:

- **Authenticity:** l'utente deve poter distinguere l'output legittimo da un contenuto sintetico non autorizzato;
- **Authorization:** ogni agente deve usare soltanto azioni, memorie e tool necessari;
- **Integrity:** prompt, RAG, feedback, messaggi e artefatti non devono essere alterati;
- **Confidentiality:** voce, conversazioni, memoria e asset di clonazione possono contenere dati sensibili;
- **Availability:** il sistema deve degradare in modo sicuro senza bloccarsi o bypassare i controlli;
- **Non-repudiation:** modifiche persistenti, accessi alla voce e azioni cross-agent devono essere attribuibili.

7.2 Data assets

Tabella 5: Data assets della pipeline agentica.

ID	Asset	Funzione e sensibilità	Proprietà prioritarie
D1	Input voce/testo	Canale controllato dall'utente; può includere PII, dati sanitari, istruzioni malevole o audio manipolato	C, I, Authenticity
D2	Partial transcript	Prime parole inviate al Fast-Brain; contesto incompleto e forte influenza sul filler immediato	I, Authenticity
D3	Full transcript	Base della risposta principale e del retrieval; può contenere dati sensibili	C, I
D4	System/personality prompt	Definisce identità, vincoli, stile e policy dei due agenti	C, I, Authenticity
D5	FAISS index, chunk, embedding e metadata	Determinano il contesto recuperato; persistenza e provenienza sono critiche	I, Authenticity, Availability
D6	RAG context	Contenuto non trusted inserito nel prompt del Deep-Brain	I, C
D7	Memoria di sessione/persistente	Influenza conversazioni future; possibile cross-user leakage	C, I, Authorization
D8	Few-shot pool	Condiziona stabilmente output e stile; promozione non controllata causa poisoning	I, Authenticity
D9	Feedback esplicito e implicito	Può modificare ranking e selezione degli esempi	I, Non-repudiation
D10	Filler e trigger JSON	Output immediato del Fast-Brain, consumato prima della risposta principale	I, Authorization, Authenticity
D11	Main response transcript	Risposta sostanziale destinata al TTS e al video	I, C, Authenticity
D12	Therapist WAV / voice embedding	Asset biometrico e identitario che abilita la clonazione vocale	C, Authenticity, Authorization
D13	Reference video e prompt visuale	Definiscono l'identità visiva e lo stile dell'avatar	I, Authenticity
D14	Artefatti intermedi	Audio TTS, cloned.wav, silent.mp4 e file temporanei	C, I, Availability
D15	Output finale e metadata	Contenuto attribuito al digital human, potenzialmente persuasivo	Authenticity, I, C
D16	Audit trail	Ricostruisce input, decisioni, tool call, policy decision e modifiche persistenti	I, Non-repudiation, C

7.3 Model assets

Tabella 6: Model assets.

ID	Modello	Ruolo	Rischi specifici
M1	Fast-Brain model	Intent preliminare, filler e trigger a bassa latenza	Goal hijack, output fuori scope, supply-chain compromise
M2	Deep-Brain LLM	Risposta principale e uso del contesto RAG	Prompt injection, data disclosure, context misuse
M3	Embedding model	Rappresentazione della query e dei chunk	Retrieval manipulation, drift, inconsistenza di versione
M4	VAD/STT	Segmentazione e trascrizione dell'audio	Adversarial audio, truncation e transcript mismatch
M5	Arabic TTS	Sintesi della voce nel dialetto previsto	Testo/SSML malevolo, provider risk, output non coerente
M6	Voice-cloning model	Replica l'identità vocale a partire dal riferimento	Identity abuse, extraction e uso non autorizzato
M7	Video generation model	Generazione visuale/cinematica	Off-prompt output, provider risk, content-policy failure
M8	Lip-Sync engine	Sincronizzazione audio-video	Artifact tampering, desincronizzazione e DoS

7.4 Supporting agentic assets

Tabella 7: Asset agentici di supporto.

ID	Asset	Funzione	Rischio dominante
A1	Agent identity / service account	Identifica Fast-Brain, Deep-Brain, orchestratore e servizi	Spoofing, privilege abuse
A2	API token e credenziali	Autorizzano accesso a RAG e tool	Leakage, scope eccessivo, mancata revoca
A3	Policy e JSON Schema	Definiscono output e azioni consentite	Tampering o bypass
A4	Messaggi inter-agent	Trasportano output, stato, sequenze e session binding	Replay, tampering, identity spoofing
A5	Orchestration state	Coordina fork, transizione, retry e fallback	Race condition e cascading failure
A6	Runtime/container	Esegue agenti e servizi	Escape, resource exhaustion, misconfiguration
A7	Model registry e pipeline di deploy	Distribuiscono modelli, prompt e dipendenze	Supply-chain compromise

8 Identificazione delle minacce

8.1 STRIDE-AI applicato direttamente alle threat concrete

STRIDE-AI viene usato come classificatore delle minacce, non come punteggio assegnato astrattamente a ogni asset. La tabella seguente mantiene la tracciabilità fra threat, asset, proprietà, categoria STRIDE e rischio OWASP.

Tabella 8: Threat catalogue sintetico.

ID	Threat concreta	Asset	Proprietà	STRIDE / OWASP	Priorità
T1	Prompt injection nei token parziali ridefinisce il goal del Fast-Brain	D2, D4, M1	I, Authenticity	Tampering / ASI01	Alto
T2	Adversarial audio o segmentazione STT produce un partial transcript malevolo	D1–D3, M4	I, Authenticity	Tampering, Spoofing / ASI01	Alto
T3	Feedback coordinato altera ranking o few-shot pool	D5, D8, D9	I, Non-repudiation	Tampering / ASI06	Critico
T4	Il Fast-Brain usa credenziali o endpoint riservati al Deep-Brain	A1, A2, D7	Authorization	Elevation of Privilege / ASI03	Critico
T5	Replay o modifica di trigger e completion signal	D10, A4, A5	I, Authenticity	Tampering, Spoofing / ASI07	Alto
T6	Furto o uso non autorizzato del voice asset per impersonare il personaggio	D12, M6, D15	C, Authenticity	Disclosure, Spoofing / ASI03, ASI09	Critico
T7	Modello, libreria o servizio esterno compromesso	M1–M8, A7	I, C	Tampering / ASI04	Alto
T8	Flooding o input costosi saturano GPU, video path o lip-sync	M7, M8, A6	Availability	Denial of Service / ASI08	Medio
T9	Filler persuasivo richiede PII o induce l'utente ad accettare guida malevola	D10, D15, M1	Authenticity, C	Spoofing, Tampering / ASI09	Alto
T10	Fast-Brain o Deep-Brain devia stabilmente dalla policy dopo aggiornamento o prompt tampering	D4, M1, M2, A7	I, Authenticity	Tampering / ASI10	Medio
T11	Artefatti audio-video intermedi vengono sostituiti prima del lip-sync	D14, D15	I, Authenticity	Tampering / ASI02, ASI04	Alto
T12	Log incompleti impediscono di attribuire modifiche a memoria, feedback o voice asset	D9, D12, D16	Non-repudiation	Repudiation / trasversale	Medio

8.2 Applicabilità dell'OWASP Top 10 for Agentic Applications

Tabella 9: Applicabilità OWASP Agentic 2026.

ID	Rischio	Applicabilità	Motivazione nella pipeline
ASI01	Agent Goal Hijack	Alta	Il Fast-Brain riceve input utente parziale e produce un'azione comunicativa immediata
ASI02	Tool Misuse & Exploitation	Condizionata	È rilevante solo se l'agente controlla invocazione o parametri sensibili dei servizi; non basta che TTS e lip-sync esistano
ASI03	Identity & Privilege Abuse	Alta	Agenti e servizi devono avere identità e scope separati; credenziali condivise ampliano il blast radius
ASI04	Agentic Supply Chain	Alta	Modelli, framework e servizi multimediali possono provenire da terze parti
ASI05	Unexpected Code Execution	Bassa	Nello scope non sono presenti shell, code interpreter o esecuzione dinamica di output; diventa rilevante solo in estensioni future
ASI06	Memory & Context Poisoning	Alta	RAG, feedback, few-shot pool e memoria possono influenzare interazioni future
ASI07	Insecure Inter-Agent Communication	Alta	Messaggi asincroni e segnali di stato richiedono autenticità, integrità e replay protection
ASI08	Cascading Failures	Alta	I percorsi paralleli, le risorse condivise e lo stitching possono propagare errori e DoS
ASI09	Human-Agent Trust Exploitation	Alta	Voce, volto, gesti e personalità aumentano la fiducia e il potenziale di social engineering
ASI10	Rogue Agents	Media	Modello, prompt o policy possono deviare in modo persistente; il monitoraggio deve rilevare drift e regressioni

Non applicabilità motivata di ASI05. Inserire una RCE non supportata dall'architettura indebolirebbe il threat model. ASI05 deve essere rivalutato soltanto se vengono aggiunti code interpreter, plugin dinamici, script generati o uso di `eval()`.

9 Risk prioritization

9.1 Criteri

Il rischio è valutato qualitativamente come combinazione di likelihood e impact. Non viene usato RPN. La likelihood considera accessibilità del vettore, privilegi richiesti, complessità, ripetibilità e controlli esistenti. L'impact considera dati esposti, persistenza, utenti coinvolti, propagazione, perdita di autenticità, indisponibilità e danno reputazionale.

Sono inoltre considerati quattro amplificatori agentici richiamati nelle metriche AIVSS presentate nel corso [2]:

- autonomia dell'agente;
- memoria persistente;
- interazione multi-agent;
- criticità della decisione e potere persuasivo dell'output.

9.2 Matrice qualitativa

Tabella 10: Matrice likelihood $\times$ impact.

	Impact basso	Impact medio	Impact alto
Likelihood alta	Medio	Alto	Critico
Likelihood media	Basso	Medio	Alto
Likelihood bassa	Basso	Basso	Medio

9.3 Priorità dei rischi principali

Tabella 11: Valutazione dei rischi prioritari.

ID	Rischio	Lik.	Impact	Risk	Amplificatori agentici
R1	Goal hijack del Fast-Brain	Alta	Alto	Critico	Output immediato, contesto parziale, human trust
R2	Feedback poisoning persistente	Alta	Alto	Critico	Persistenza, effetto cross-session, modifica del few-shot pool
R3	Identity/privilege abuse tra agenti	Media	Alto	Alto	Multi-agent, credenziali, accesso a memoria e tool
R4	Tampering/replay inter-agent	Media	Alto	Alto	Esecuzione asincrona, state machine e correlazione sessione
R5	Voice clone abuse e trust exploitation	Media	Alto	Alto	Identità biometrica, output persuasivo, difficile attribution
R6	Supply-chain compromise	Media	Alto	Alto	Molti servizi esterni, persistenza e difficile rilevazione
R7	Cascading failure/DoS	Media	Medio	Medio	Percorsi paralleli e risorse condivise

Per evitare falsa precisione, non viene assegnato un AARS numerico in assenza del calcolatore e della formula completa utilizzati dal corso. Per i rischi R1–R5 si conserva comunque un vettore descrittivo di exploitability e impatto nella sezione successiva.

10 Scenari di minaccia prioritari

10.1 Scenario 1 — Goal hijack del Fast-Brain

Classificazione: STRIDE Tampering; OWASP ASI01, con possibile propagazione verso ASI09.

Asset: partial transcript, system/personality prompt, Fast-Brain, filler, trigger JSON.

Precondizioni: l'attaccante può inviare voce o testo; il Fast-Brain opera su input parziale; l'output viene sintetizzato prima della risposta principale.

Attack path:

1. L'attaccante inserisce nei primi token un'istruzione che tenta di ridefinire il compito del Fast-Brain.
2. Lo STT produce un partial transcript privo del contesto che seguirebbe nella frase completa.
3. Il modello interpreta l'istruzione come prioritaria rispetto al ruolo di semplice filler.

4. Viene prodotto un filler che risponde alla domanda, chiede dati sensibili o induce l'utente a compiere un'azione.
5. Il contenuto viene pronunciato prima che il Deep-Brain e i controlli del percorso principale possano correggerlo.

Impatto: compromissione dell'integrità conversazionale, social engineering, possibile disclosure di PII e perdita di fiducia.

Vettore qualitativo ispirato ad AIVSS: AV:N, AC:L, AT:N, PR:N, UI:P; C:M, I:H, A:L; autonomia media, memoria bassa, multi-agent media, trust impact alto.

Detection signals: filler interrogativi, richiesta di PII, presenza di imperativi, overlap semantico con una risposta sostanziale, trigger non coerente, violazione del limite di parole.

Controlli chiave: least agency, JSON Schema, trigger enum, content policy deterministica, PII detection, timeout e filler statico pre-approvato.

10.2 Scenario 2 — Feedback poisoning persistente

Classificazione: STRIDE Tampering e Repudiation; OWASP ASI06.

Asset: feedback esplicito/implicito, ranking, FAISS metadata, few-shot pool, audit trail.

Precondizioni: il feedback influenza ranking o selezione degli esempi; i contributi non sono sufficientemente autenticati, deduplicati o limitati.

Attack path:

1. L'attaccante crea più sessioni o account e ripete feedback positivi su risposte associate a chunk malevoli.
2. In parallelo penalizza chunk corretti tramite feedback negativo o replay.
3. Il sistema aggiorna score o promuove esempi nel few-shot pool senza una soglia robusta e senza provenienza affidabile.
4. Le query future recuperano più frequentemente contenuto manipolato.
5. Il Deep-Brain produce risposte distorte per utenti diversi dall'attaccante.

Impatto: integrità compromessa in modo persistente, effetto cross-session, difficile rollback se non esistono versioning e audit.

Vettore qualitativo: AV:N, AC:L–M, AT:N, PR:L, UI:N; C:L, I:H, A:L; autonomia media, memoria alta, multi-agent media, decision criticality media-alta.

Detection signals: burst di feedback, account correlati, distribuzioni anomale, variazioni improvvise del top- k , promozione di chunk senza evidenza sufficiente.

Controlli chiave: feedback autenticato, rate limit, anti-replay, robust aggregation, separazione fra feedback e update persistente, provenance, versioning, rollback e HITL per promozioni ad alto impatto.

10.3 Scenario 3 — Identity and privilege abuse tra agenti

Classificazione: STRIDE Elevation of Privilege e Spoofing; OWASP ASI03.

Asset: service account, API token, endpoint RAG, memoria, orchestratore.

Precondizioni: Fast-Brain e Deep-Brain condividono credenziali oppure le API non verificano lo scope dell'identità chiamante.

Attack path:

1. Il Fast-Brain viene compromesso tramite goal hijack o supply-chain compromise.

2. Il processo usa il token condiviso per invocare un endpoint riservato al Deep-Brain.
3. Legge memoria, recupera dati non necessari o propone una modifica persistente.
4. L'azione appare provenire da un'identità legittima e può non essere distinta nei log.
5. Il blast radius passa dal solo filler all'intera pipeline.

Impatto: accesso non autorizzato a memoria e contesto, possibile esfiltrazione, modifica persistente e compromissione dell'orchestratore.

Vettore qualitativo: AV:A/N, AC:M, AT:P, PR:L, UI:N; C:H, I:H, A:M; autonomia alta dopo la compromissione, memoria alta, multi-agent alta.

Detection signals: chiamate RAG dall'identità Fast-Brain, uso di scope anomali, token fuori contesto, accessi incompatibili con il ruolo.

Controlli chiave: identità distinte, token short-lived, audience e scope binding, deny-by-default, policy enforcement point, network segmentation e audit per azione cross-agent.

10.4 Scenario 4 — Tampering e replay dei messaggi inter-agent

Classificazione: STRIDE Tampering e Spoofing; OWASP ASI07.

Asset: messaggi Fast-Brain/orchestratore, trigger, sequence number, session ID, completion signal.

Precondizioni: il canale o il message bus non garantisce autenticità end-to-end, freschezza e binding alla sessione.

Attack path:

1. L'attaccante intercetta o ottiene un messaggio valido del Fast-Brain.
2. Modifica il trigger oppure reinvia il messaggio in una sessione diversa.
3. L'orchestratore verifica solo la correttezza sintattica del JSON.
4. Il messaggio viene accettato come fresco e proveniente dall'agente corretto.
5. L'avatar esegue un gesto errato, riproduce un filler non correlato o entra in uno stato inconsistente.

Impatto: corruzione dello stato, output inappropriato, race condition, potenziale cascading failure.

Vettore qualitativo: AV:A, AC:M, AT:P, PR:L, UI:N; C:L, I:H, A:M; multi-agent alta.

Detection signals: sequence duplicate, timestamp fuori finestra, session mismatch, agent ID non coerente, ordine degli stati impossibile.

Controlli chiave: mTLS o identità workload equivalente, autenticazione applicativa quando il bus persiste i messaggi, nonce/sequence, expiry, idempotency key e state machine deterministica.

10.5 Scenario 5 — Voice clone abuse e human-agent trust exploitation

Classificazione: STRIDE Spoofing e Information Disclosure; OWASP ASI03, ASI04 e ASI09.

Asset: Therapist WAV, voice embedding, credenziali TTS, personality prompt, output finale e meta-data.

Precondizioni: l'attaccante ottiene il voice asset, il relativo embedding o le credenziali del servizio di clonazione.

Attack path:

1. Il voice asset viene copiato tramite storage mal configurato, insider o provider compromesso.
2. L'attaccante genera audio nella voce dell'avatar e produce un video coerente.
3. Il contenuto usa tono, formule linguistiche e gesti associati alla personalità legittima.

4. L'utente attribuisce il messaggio al sistema autentico.
5. Il contenuto può chiedere PII, promuovere rimedi non sicuri o fornire indicazioni fraudolente.

Impatto: impersonazione highly credibile, danno reputazionale, disclosure di dati, rischio di guida dannosa e difficile attribution.

Vettore qualitativo: AV:N, AC:M, AT:P, PR:L/H, UI:A; C:H, I:H, A:L; trust impact molto alto.

Detection signals: accessi anomali al voice vault, generazioni senza sessione valida, assenza di provenance, output non associato a un audit ID.

Controlli chiave: voice vault cifrato, accesso esclusivo del voice service, credenziali temporanee, watermark/provenance, audit, revoca, disclosure chiara della natura sintetica e policy che vieta richieste di PII.

11 Controlli secondo le sette precauzioni

11.1 Precauzione 1 — Least Agency

Least Agency estende least privilege alle capacità di ragionamento, memorie, tool e azioni dell'agente [2]. Applicazioni concrete:

- il Fast-Brain può produrre soltanto filler, intent label e trigger appartenenti a una whitelist;
- il Fast-Brain non accede a FAISS, memoria persistente, feedback store, voice asset o generazione video;
- il Deep-Brain usa il RAG in read-only durante l'inferenza;
- il Feedback Manager propone aggiornamenti, ma non promuove autonomamente contenuti ad alto impatto;
- l'orchestratore applica una sequenza deterministica e non interpreta output come codice;
- ogni identità ha scope, audience e durata minima necessari.

11.2 Precauzione 2 — Guardrail deterministici e HITL

Guardrail sincroni sul Fast-Brain:

- JSON Schema strict;
- filler con lunghezza massima;
- trigger da enum;
- divieto di richieste di PII e di consigli sostanziali;
- filtro per domande, imperativi e contenuti fuori policy;
- session binding e sequence validation;
- fallback statico quando un controllo fallisce o il timeout scade.

HITL per azioni ad alto impatto:

- modifica del voice asset o del personality prompt;
- promozione persistente nel few-shot pool;
- modifica del set di trigger o delle policy;
- rilascio di nuovi modelli o provider;
- aggiornamenti permanenti dell'indice RAG;
- output in domini sensibili quando il sistema formula raccomandazioni mediche o finanziarie.

11.3 Precauzione 3 — Sandboxing e controllo granulare degli accessi

- container o runtime isolati per agenti, TTS, voice service e lip-sync;
- identità workload separate e token short-lived;
- deny-by-default su rete e file system;
- voice asset in storage dedicato, cifrato e accessibile solo al voice service;
- FAISS read-only nel serving path e update path separato;
- egress control verso provider esterni;
- quote e limiti di risorse per prevenire cascading failure.

11.4 Precauzione 4 — Audit trail completo e immutabile

L'audit trail deve registrare:

- input e transcript, con protezioni per i dati sensibili;
- partial transcript inviato al Fast-Brain;
- versione di modello, prompt, policy e schema;
- filler, trigger, risultato dei controlli e fallback;
- agent identity, tool invocation, timestamp e outcome;
- chunk RAG recuperati, score e provenance;
- feedback, deduplicazione e modifiche a ranking/few-shot;
- accessi al voice asset e generazioni del voice service;
- transizioni della state machine e timeout.

Non è necessario memorizzare ragionamenti privati completi. Per la ricostruzione dell'incidente sono sufficienti decision trace, input/output, tool call, policy decision e motivazione sintetica.

11.5 Precauzione 5 — Supply chain control

- registry approvato per modelli e container;
- firme, hash e versioni bloccate;
- SBOM per librerie, servizi e modelli;
- scansione delle dipendenze e verifica della serializzazione sicura;
- test in shadow mode prima del rilascio;
- rollback rapido di modelli, prompt e policy;
- due diligence sui provider TTS, voice e video;
- registrazione della versione di ogni componente usato per generare l'output.

11.6 Precauzione 6 — Continuous execution monitoring

Il monitoraggio deve rilevare:

- filler che risponde alla domanda o richiede dati;
- goal drift e trigger anomali;
- accessi incompatibili con il ruolo dell'agente;
- replay, session mismatch e sequence duplicate;
- burst di feedback e variazioni anomale del top- k ;
- consumo GPU, timeout, retry e loop;

- Double-Speak e transizioni di stato impossibili;
- generazioni vocali prive di sessione o audit ID;
- deviazioni persistenti dopo un aggiornamento.

Devono esistere kill-switch, circuit breaker, limiti massimi di passi e graceful degradation.

11.7 Precauzione 7 — Audit periodici ispirati ad AIVSS

Gli audit devono essere ripetuti:

- dopo ogni modifica a modello, prompt, memoria o tool;
- quando cambia il livello di autonomia;
- quando viene aggiunto un nuovo provider;
- dopo incidenti o rilevazioni di drift;
- periodicamente tramite red teaming multilingue e multimodale.

L'audit riesamina vettore d'attacco, complessità, requisiti, privilegi, interazione utente, impatto CIA e amplificatori agentici.

12 Secure architecture proposal

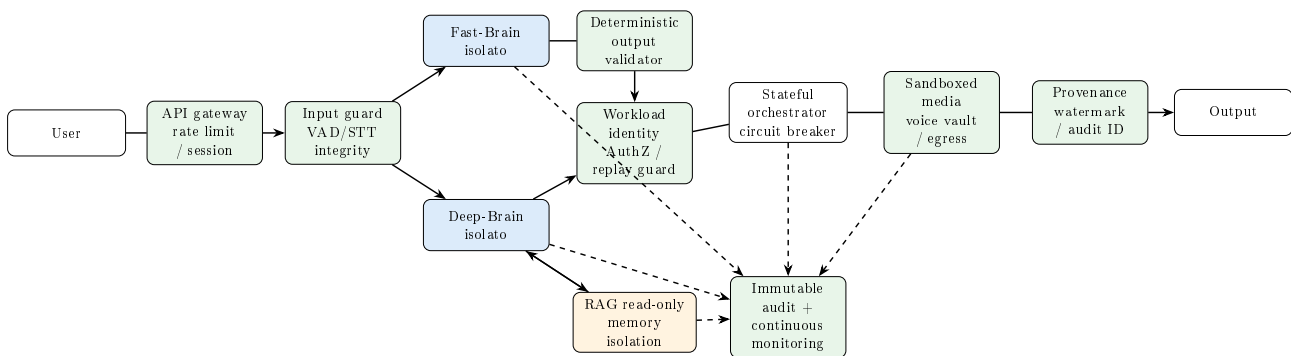


Figura 5: Secure architecture proposta.

Tabella 12: Controlli per trust boundary.

TB	Controllo	Funzione	Threat ridotte
TB1	API gateway, rate limit, session management	Limita abuso dell'input e associa ogni richiesta a un principal	T1, T2, T8, T9
TB2	Input guard e partial/full transcript correlation	Controlla formato, durata, lingua e coerenza dei transcript	T1, T2
TB3	Workload identity, AuthZ, schema, nonce e sequence	Autentica agenti e messaggi, impedisce accessi fuori ruolo e replay	T4, T5
TB4	RAG read-only, update gate, provenance e versioning	Separa serving e update, limita poisoning persistente	T3, T4, T12
TB5	Sandboxing, voice vault, egress control e signed artifacts	Limita tool misuse, furto della voce e supply-chain impact	T6, T7, T11
TB6	Provenance, watermark, audit ID e transparency disclosure	Rafforza autenticità e attribution dell'output	T6, T9, T11

12.1 Fail-safe behavior

Il sistema non deve scegliere fra sicurezza e latenza. Se il Fast-Brain non produce un output valido entro il budget, l'orchestratore usa un filler statico pre-approvato oppure mantiene un'animazione idle sicura. Non deve mai inoltrare un output non validato soltanto per rispettare il tempo target.

13 Trade-off sicurezza–latenza

I controlli sono suddivisi in base al loro posizionamento nel percorso critico.

Tabella 13: Posizionamento dei controlli.

Classe	Esempi	Posizionamento	Overhead atteso
Sincroni deterministici	JSON Schema, enum, length check, session/sequence binding, allow/deny policy	Prima del TTS filler	Trascurabile o basso; da misurare
Sincroni leggeri	PII detection, request rate limit, classificatore di policy compatto	Edge e output validator	Basso; da misurare
Asincroni	Anomaly detection, analisi feedback, correlazione dei log, drift monitoring	Fuori dal critical path	Non blocca il filler
Offline	Red teaming, scansione supply chain, AIVSS audit, model evaluation	CI/CD e audit periodico	Nessun impatto runtime

Non vengono indicati valori in millisecondi non misurati. La validazione sperimentale dovrà quantificare l'overhead reale e il tasso di attivazione del fallback.

14 Piano di validazione sperimentale

Questa sezione definisce esperimenti riproducibili. Non vengono presentati risultati empirici perché non sono ancora stati eseguiti. Le tabelle sono predisposte per essere completate dopo l'implementazione.

14.1 Esperimento A — Fast-Brain security harness

Obiettivo: verificare che il validator impedisca filler e trigger fuori policy senza introdurre un overhead incompatibile con il fast path.

Dataset:

- input benigni;
- direct prompt injection nei primi token;
- input troncati e ambigui;
- inglese, arabo standard, dialetto emiratino e code-switching;
- richieste di PII e consigli sostanziali;
- output JSON malformati o con trigger non autorizzato.

Metriche: policy violation rate, invalid JSON rate, unsafe filler rate, fallback activation rate, false positive rate e tempo di validazione.

Tabella 14: Template risultati Esperimento A.

Metrica	Baseline	Con controlli	Target/nota
Unsafe filler rate	Da misurare	Da misurare	Riduzione significativa
Invalid trigger accepted	Da misurare	Da misurare	0
False positive rate	–	Da misurare	Compatibile con UX
Validation latency	–	Da misurare	Entro il budget definito
Fallback activation rate	–	Da misurare	Monitorato, non nascosto

14.2 Esperimento B — Feedback poisoning simulation

Obiettivo: confrontare un aggiornamento diretto del ranking con un sistema protetto da autenticazione, rate limit, deduplicazione, anti-replay, robust aggregation e update gate.

Metriche: numero di feedback richiesto per portare un chunk malevolo nel top- k , percentuale di query compromesse, tempo di rilevamento e correttezza del rollback.

Tabella 15: Template risultati Esperimento B.

Metrica	Baseline	Sistema sicuro	Interpretazione
Feedback per entrare nel top- k	Da misurare	Da misurare	Più alto è migliore
Query compromesse	Da misurare	Da misurare	Più basso è migliore
Replay accettato	Da misurare	Da misurare	Target: no
Tempo di rollback	–	Da misurare	Ripristino della versione precedente

14.3 Esperimento C — Sicurezza dei messaggi inter-agent

Obiettivo: verificare il rifiuto di trigger modificati, session mismatch, duplicate sequence, messaggi scaduti e agent ID falsi.

Tabella 16: Test case dei messaggi inter-agent.

Test	Controllo atteso	Esito atteso
Trigger modificato	Schema + signature/MAC applicativo se richiesto	Rifiutato
Session ID diverso	Session binding	Rifiutato
Sequence duplicata	Replay cache / idempotency	Rifiutato
Timestamp fuori finestra	Expiry check	Rifiutato
Agent ID falso	Workload identity e authorization	Rifiutato
Filler oltre il limite	Schema e content policy	Fallback

15 Rischio residuo

Tabella 17: Valutazione qualitativa del rischio residuo atteso.

Scenario	Controlli principali	Iniziale	Residuo	Motivazione
Goal hijack Fast-Brain	Least agency, validator, fallback, monitoring	Critico	Medio	I guardrail riducono l'impatto, ma input linguistici adattivi restano possibili
Feedback poisoning	Auth feedback, update gate, robust aggregation, rollback	Critico	Medio	La persistenza è confinata e reversibile, ma Sybil sofisticati restano un rischio
Privilege abuse	Identità separate, token short-lived, policy deny-by-default	Alto	Basso-Medio	Il Fast-Brain non possiede più gli accessi utili alla propagazione
Replay inter-agent	Workload identity, nonce, sequence, expiry	Alto	Basso	Messaggi non freschi o fuori sessione vengono rifiutati
Voice clone abuse	Voice vault, provenance, audit, revoca	Alto	Medio	Un output sintetico ottenuto fuori sistema può essere difficile da eliminare completamente

Il rischio residuo deve essere rivalutato dopo la validazione sperimentale. I valori sopra rappresentano una previsione progettuale, non risultati misurati.

16 Limitazioni

- L'architettura è descritta a livello progettuale; deployment, provider e protocolli effettivi possono modificare likelihood e controlli necessari.
- Non sono stati eseguiti test empirici; la sezione di validazione contiene un piano e template di risultati.
- La valutazione del rischio è qualitativa. Non viene calcolato un AARS numerico senza lo strumento e la formula usati nel corso.
- La robustezza multilingue e dialettale dei guardrail deve essere verificata sperimentalmente.
- Il threat model non dimostra l'assenza di backdoor nei modelli; riduce il rischio tramite provenance, firme, testing e rollback.
- Privacy, compliance e consenso per voice cloning richiedono un'analisi dedicata oltre al threat model tecnico.
- L'uso dell'avatar in contesti di salute aumenta la decision criticality e richiede policy di contenuto e supervisione umana più restrittive.

17 Conclusioni

La pipeline dual-brain riduce la latenza percepita, ma introduce superfici d'attacco specifiche: il Fast-Brain agisce su input parziale, i due agenti devono coordinarsi, memorie e feedback possono persistere, e l'output audiovisivo sfrutta una forte identità umana. Il rischio non deriva soltanto dal modello linguistico, ma dall'interazione fra identità, memoria, tool, orchestrazione e fiducia dell'utente.

Il threat modeling ha mostrato come i rischi prioritari siano goal hijack, feedback poisoning, identity/privilege abuse, comunicazione inter-agent insicura e abuso della voce clonata. ASI05 è stato correttamente considerato non applicabile nello scope corrente, evitando di introdurre scenari RCE non supportati dall'architettura.

La strategia proposta applica le sette precauzioni del corso e adotta un principio centrale: **la bassa latenza non deve mai giustificare il bypass dei controlli**. I controlli deterministici restano nel fast path; monitoraggio, audit e analisi più costose operano in modo asincrono; in caso di errore il sistema usa un fallback statico sicuro. La separazione delle identità e la least agency limitano il blast radius, mentre provenance, voice vault e update gate proteggono gli asset più caratterizzanti della pipeline.

Il passo successivo è implementare il security harness e la simulazione di feedback poisoning, completando le tabelle sperimentali con valori misurati. Questo permetterà di trasformare il threat model progettuale in una valutazione verificata e riproducibile.

A JSON Schema semplificato del Fast-Brain

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "type": "object",
  "additionalProperties": false,
  "required": ["session_id", "intent", "trigger", "filler", "sequence"],
  "properties": {
    "session_id": {"type": "string", "minLength": 16, "maxLength": 128},
    "intent": {
      "type": "string",
      "enum": [
        "complex_analytical",
        "opinion_affective",
        "factual_search",
        "controversial_defensive",
        "generic_acknowledgement"
      ]
    },
    "trigger": {
      "type": "string",
      "enum": [
        "GAZE_UP_LEFT",
        "HEAD_NOD_SLIGHT",
        "LEAN_IN_BOOK",
        "HAND_GESTURE_OPEN",
        "IDLE_THINKING"
      ]
    },
    "filler": {"type": "string", "minLength": 1, "maxLength": 120},
    "sequence": {"type": "integer", "minimum": 0}
  }
}
```

```
}
```

La lunghezza in caratteri non sostituisce il controllo applicativo sul numero di parole. Il validator deve inoltre applicare content policy, PII detection e divieto di richieste all'utente.

B Formato sicuro del messaggio inter-agent

```
{
  "message_id": "uuid",
  "session_id": "9f4b...",
  "agent_id": "fast-brain-prod-eu-01",
  "audience": "orchestrator-prod-eu",
  "issued_at": "2026-07-23T14:22:18Z",
  "expires_at": "2026-07-23T14:22:20Z",
  "sequence": 12,
  "idempotency_key": "9f4b...:12",
  "payload": {
    "intent": "complex_analytical",
    "trigger": "GAZE_UP_LEFT",
    "filler": "That is an important question; let me think carefully."
  },
  "policy_version": "fastbrain-policy-3.2",
  "schema_version": "1.0"
}
```

Il trasporto deve autenticare l'identità del workload. Se il messaggio è persistito, inoltrato attraverso più trust domain o necessita di verifica end-to-end, è opportuno aggiungere una firma o un MAC applicativo. Sequence, expiry e idempotency impediscono replay e duplicazione.

C Matrice di tracciabilità

Tabella 18: Tracciabilità threat–controlli–test.

Threat	OWASP / STRIDE	Controlli	Validazione
Goal hijack	ASI01 / Tampering	Least agency, validator, fallback	Esperimento A: prompt injection multilingue
Feedback poisoning	ASI06 / Tampering	Auth, anti-replay, update gate, rollback	Esperimento B: top- <i>k</i> poisoning simulation
Privilege abuse	ASI03 / EoP	Workload identity, scoped token, AuthZ	Test negativo: Fast-Brain chiama endpoint RAG
Inter-agent replay	ASI07 / Spoofing, Tampering	Nonce, sequence, expiry, session binding	Esperimento C
Voice clone abuse	ASI09 / Spoofing, Disclosure	Voice vault, provenance, audit, revoca	Test accessi e generazioni senza audit ID

Threat	OWASP / STRIDE	Controlli	Validazione
Supply chain	ASI04 / Tampering	Firma, SBOM, scanning, shadow mode	Verifica artefatto e rollback
Cascading failure	ASI08 / DoS	Quote, timeout, circuit breaker, fallback	Load e fault-injection test

Riferimenti bibliografici

- [1] Project specification, *Agentic filler loop for a real-time digital human pipeline*, materiale fornito per il progetto, 2026.
- [2] E. Damiani, *Security Precautions for Agentic Systems: Seven Key Practices for Safe Data-Intensive Architectures*, slide del corso Sicurezza delle Architetture Data Intensive, Università degli Studi di Milano, 20 aprile 2026.
- [3] E. Damiani, *Talking Avatar with RAG Pipeline using Veo 3.1: Asset Model, Failure Modes, and Threat Analysis using STRIDE-AI*, slide del corso, 4 maggio 2026.
- [4] Project material, *The Legend of Al-Hakima Umm Saif e Core Personality Traits*, 2026.
- [5] Project material, *Verbal Habits & Response Guidelines*, 2026.
- [6] L. Mauri and E. Damiani, “STRIDE-AI: An Approach to Identifying Vulnerabilities of Machine Learning Assets,” *IEEE International Conference on Cyber Security and Resilience*, 2021.
- [7] L. Mauri and E. Damiani, “Modeling Threats to AI-ML Systems Using STRIDE,” *Sensors*, 2022.
- [8] OWASP Foundation, *OWASP Top 10 for Agentic Applications 2026*, 2026.
- [9] OWASP Foundation, *OWASP Top 10 for Large Language Model Applications 2025*, 2025.
- [10] S. Yao et al., “ReAct: Synergizing Reasoning and Acting in Language Models,” 2023.
- [11] NIST, *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, 2023.
- [12] MITRE, *ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems*.
- [13] IETF, *Security Architecture for WebRTC and WebRTC Security Considerations*, RFC 8827 and RFC 8826, 2021.